PrepPressure — Master Project Specification (v3, users + authentication)

> Commit as `docs/SPECIFICATION.md`. Exact field names, URLs and error codes live in `docs/API-CONTRACT.md`; if this file and the contract ever disagree, **the contract wins** and the team fixes this file.

1. What the application is

PrepPressure is an interview-practice platform.

- A visitor **registers** and **logs in**. Login returns a **JWT access token**.
- The token is sent with **every** request as `Authorization: Bearer <token>`. Only `POST /auth/register` and `POST /auth/login` work without a token.
- A user can create **questions** (three types: `multiple_choice`, `short_answer`, `code_output`).
- A user can create **interviews**. An interview is a titled quiz made of **1 to 20 questions** with a **total time limit**.
- **Everyone (logged in) can see** all questions and all interviews. **Only the owner** can edit or delete them.
- Any user can **take** any interview. Each time is an **attempt** with a timer. When the attempt ends (finished manually or timed out), the user sees a **result page** for that attempt.
- Each user has a **profile page** showing their information and statistics (questions created, interviews created, attempts completed, questions answered, average and best score...).
- The backend serves a **Swagger UI at `/docs`** where every endpoint can be tried, including an "Authorize" button for the token.

Removed from v2: display-name history (replaced by real users), the internal-tool key guard (replaced by ownership), the voice recorder (out of scope).

2. Tech stack

- Frontend: React + TypeScript (Vite), React Router.
- Backend: NestJS + TypeScript, MongoDB with Mongoose, `@nestjs/jwt` + `@nestjs/passport` (or a hand-written guard using `@nestjs/jwt`), `bcrypt` for password hashing, `class-validator` / `class-transformer`, `@nestjs/swagger`.
- Course rules kept: **no `populate`**, **no aggregation pipelines**, **numeric public IDs** (never expose ObjectId), **never execute candidate-written code**, **no secrets committed**.

3. Data model (summary — exact stored shapes are in the contract, section 8)

User

`id` (number), `username` (unique, lowercase), `email` (unique, lowercase), `passwordHash` (never returned), `displayName`, `bio` (optional), `createdAt`, `updatedAt`.

Question

`id`, `ownerId`, `prompt`, `category`, `difficulty` (`easy` | `medium` | `hard`), `type`, type-specific data, `createdAt`, `updatedAt`.

- `multiple_choice`: `choices` = 2–6 items `{ id, text, isCorrect }`, **exactly one** correct.
- `short_answer`: `expectedKeywords` = 2–6 strings, `requiredKeywordCount` from 1 to the number of keywords.
- `code_output`: `codeSnippet` (display-only text) and `expectedOutput` (non-empty). **No code is ever executed.**

Answer keys (`isCorrect`, `expectedKeywords`, `requiredKeywordCount`, `expectedOutput`) are only returned to the **question's owner** on the question endpoints. Everyone else, and every interview/attempt endpoint, gets the safe version.

Interview

`id`, `ownerId`, `title`, `description`, `category`, `difficulty`, `questionIds` (1–20 distinct, all must exist), `timeLimitSeconds` (30–3600), `createdAt`, `updatedAt`.

Attempt

`id`, `interviewId`, `userId`, `status` (`in_progress` | `finished` | `timed_out`), `startedAt`, `deadlineAt`, `finishedAt`, `questions` (a **snapshot** copied from the questions at start, including private scoring data stored internally), `answers`, `score`, `maxScore`, `percentage`, `readiness`.

The snapshot means editing or deleting a question/interview later **never changes** an old attempt or its results.

4. Ownership and permission rules

Action	Who is allowed
Register / login	Anyone (no token)
Read questions, interviews, user profiles	Any logged-in user
Edit / delete a question or interview	Only its owner (`403 NOT_OWNER` otherwise)
See answer keys of a question	Only the question owner
Start an attempt on any interview	Any logged-in user (including the interview owner)
Read / answer / finish an attempt, see its results	Only the user who started it (`403 NOT_OWNER`)
Edit own profile (`displayName`, `bio`)	Only that user, via `/users/me`

Delete rules:

- A **question** referenced by any interview **or** any attempt snapshot cannot be deleted → `409 QUESTION_IN_USE`.
- An **interview** can be deleted by its owner at any time. Existing attempts keep their snapshot and still show results.

5. Attempt timing

- `deadlineAt = startedAt + interview.timeLimitSeconds`.
- Answers are accepted until `deadlineAt + 5 seconds` (network grace).
- An attempt still `in_progress` after `deadlineAt + 5s` is switched to `timed_out` **the next time it is read or written** (lazy timeout — no background jobs needed), and its score is calculated at that moment.
- `finished` and `timed_out` are terminal: no more answers, no re-finish (`409 ATTEMPT_ENDED`).
- The frontend timer is display-only; the backend decides.

6. Scoring (deterministic, backend only)

Each question is worth **1 point**. `maxScore` = number of questions in the attempt.

- `multiple_choice`: 1 if the chosen `choiceId` is the correct one, else 0.
- `short_answer`: count expected keywords found in the answer (case-insensitive substring match). `matched >= requiredKeywordCount` → **1**; `0 < matched < requiredKeywordCount` → **0.5**; `matched = 0` → **0**.
- `code_output`: normalize both texts (`\r\n` → `\n`, trim outer whitespace), then exact comparison → 1 or 0.
- Unanswered question → 0.
- `percentage = round(score / maxScore * 100, 1 decimal)`.
- `readiness`: `< 60` → `needs_practice`; `60 to < 85` → `almost_ready`; `>= 85` → `ready`.

The client never sends a score or correctness. Results include, per question: the submitted answer, the expected answer, points earned, and a short deterministic explanation (e.g. "Matched 1 of 2 required keywords: half credit").

7. Profile statistics

`GET /users/:id/profile` returns the public user info plus: `questionsCreated`, `interviewsCreated`, `attemptsCompleted` (finished + timed_out), `attemptsInProgress`,

`questionsAnswered` (sum of answers in ended attempts), `averagePercentage` (ended attempts, null if none), `bestPercentage` (null if none). Computed with `countDocuments` and `find` + projection, **no aggregation**.

8. Swagger at `/docs`

- Swagger UI is served at `http://localhost:<PORT>/docs` (JSON at `/docs-json`).
- Bearer auth is configured so the "Authorize" button accepts the token; authorization is remembered on reload.
- Every controller has `@ApiTags`, every protected controller has `@ApiBearerAuth()`, every DTO has `@ApiProperty`, and every endpoint documents its success and error responses (400, 401, 403, 404, 409 as applicable).

9. Backend quality rules

- Global `ValidationPipe` with `whitelist: true`, `forbidNonWhitelisted: true`, `transform: true` → unknown fields are rejected.
- Passwords hashed with bcrypt; `passwordHash` never leaves the users module.
- `JWT_SECRET`, `JWT_EXPIRES_IN`, `MONGODB_URI`, `PORT`, `CORS_ORIGIN` come from `.env`; only `.env.example` is committed.
- Log meaningful events (register, login failure, attempt start/finish/timeout, question/interview create/delete); never log passwords, tokens or full answers.

10. Frontend pages

Route	Page	Owner
`/login`, `/register`	Login / register forms	Laith
`/`	Redirect to `/interviews`	Laith
`/questions`, `/questions/new`, `/questions/:id`, `/questions/:id/edit`	Question bank, create, detail, edit	Adham

Route	Page	Owner
`/interviews`, `/interviews/new`, `/interviews/:id`, `/interviews/:id/edit`	Interview list, create, detail, edit	Adham
`/interviews/:id/take`	Starts an attempt then redirects to the attempt page	Laith
`/attempts/:id`	Take the interview (timer + answers + finish)	Laith
`/attempts/:id/results`	Result page for one attempt	Laith
`/profile`	Logged-in user's profile + their attempts	Laith
`/users/:id`	Another user's public profile + stats	Laith

All routes except `/login` and `/register` require login. Edit/delete buttons are shown only to the owner (the backend still enforces it).

11. Definition of done

- Every endpoint except register/login returns `401` without a valid token.
- Non-owners get `403 NOT_OWNER` when editing/deleting; owners succeed.
- Answer keys never appear for non-owners or in any interview/attempt response while an attempt is in progress.
- Interviews with 1 question and with 20 questions both work; 0 or 21 are rejected.
- Timeout + 5 s grace, duplicate answer rejection, half credit, unanswered = 0, readiness boundaries at 60 and 85 all verified.
- Editing a question after an attempt does not change that attempt's results.
- Profile statistics match hand-counted data.
- Swagger `/docs` lists every endpoint, and every protected endpoint can be called after clicking "Authorize".
- Backend restart keeps all data (MongoDB).